

SECURITY INCIDENT / FINAL BRIEFING

Northgate Retail Ltd Security Incident Investigation

Team B Elay · Yossef · Gavriel · Submission Date: 9/1/2026

EVIDENCE WINDOW 23 MAY – 20 AUG 2026

Organisation context & investigation scope

ORGANISATION

National Supermarket Chain

2,100 employees
HQ in Rishon LeZion
branches throughout Israel

TECHNOLOGY

Internally managed payments

Card processing sits on a dedicated network. Suppliers enter through a dedicated portal.

EVIDENCE

89 days of supplied data

Raw logs and lookup data cover 23 May–20 Aug 2026.

what happened?

fraudulent transactions originating from cards used at our branches over the past two weeks

what we are asked?

Determine what happened, when it happened, which accounts and systems were involved and the scope of impact.

Bottom line up front

01

A severe security incident began with a breach of the vendor portal, from which the attacker moved laterally into the internal network, obtained administrative privileges, modified 34 point-of-sale (POS) terminals, and exfiltrated approximately 180MB of data.

02

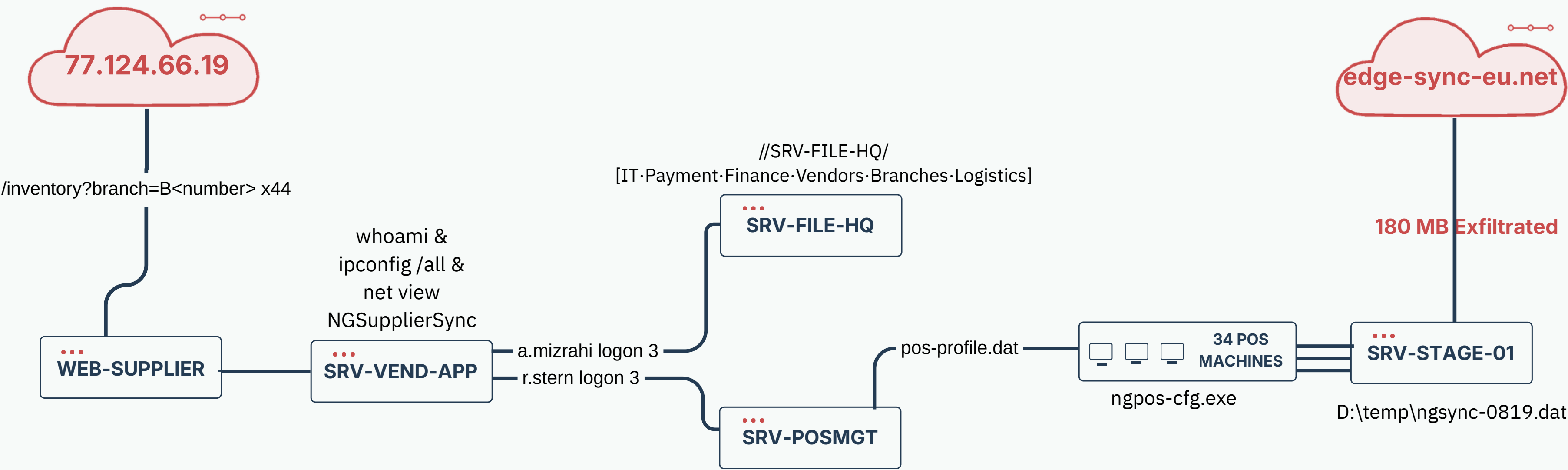
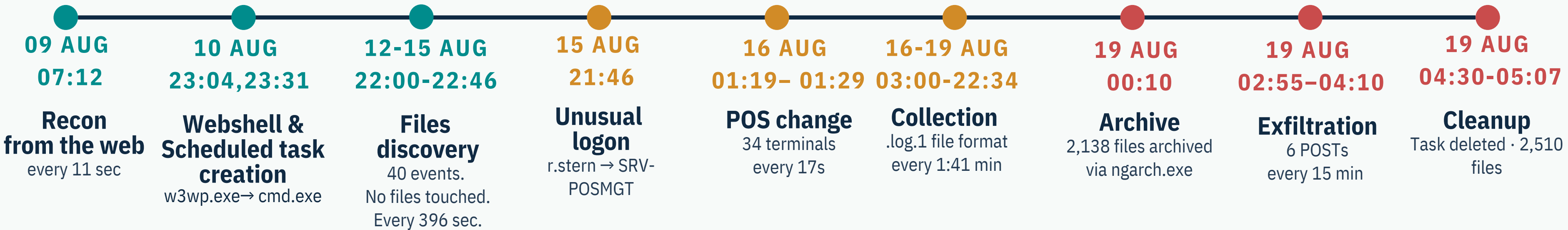
About 430 MB was uploaded on SRV-STAGE-01. allowing the data exfiltration, the attacker attempted to cover their tracks by deleting access tools and over 2,500 files.

03

The incident is not fully contained, we do not have accurate extent of the attacker's foothold in the organization's network or what information was exfiltrated.

We assume with strong confidence that our clients credit card numbers are in the absolute control of the attacker.

The Timeline



How we found it and the pivots that mattered

1 Abnormal amounts of EventCode 4688

r.stern / ngpos-cfg.exe ↔ 34 exact **POS** targets
One deployment every 17 seconds

```
index=northgate sourcetype="winevent"  
|where EventCode=4688  
|stats count by actor
```

2 **POS** branches enumeration

77.124.66.19 → 44 GETs → B01–B38 Fixed
11-second intervals

```
index=northgate sourcetype=weblog  
src_ip="77.124.66.19" | stats dc(uri_path)  
values(uri_path)
```

3 High volume write by r.stern

r.stern → *.log.1 → SRV-STAGE-01

```
index=northgate sourcetype="fileaudit"  
actor="r.stern" server="SRV-STAGE-01"  
object_path="*.log.1"
```


what we ruled out

- e.katz - Defender 1116 reviewed, no linked to malicious activity
- m.saban - activity only from WKS-IT-09 none from STAGE-01
- y.oren - solo member of a group with elevated privileges - no malicious activity on files
- SRV-CARDPROC - 74 connections only from four assigned Payments workstations
- SRV-DC-01 - found no indicator of attack
- External cloud shares — no activity detected
- Backups — 103/103 successful; no tampering indicators
- Price-file writes remained within normal parameters
- Kerberoasting — 4769/4768 review found no bulk or fixed intervals

METHODS: Timeline and Pattern Recognition , correlation in other sources, Normalizations to see spikes.

Scope & impact – confirmed versus potential

CONFIRMED

- 1. 34 / 42 POS terminals configured and harvested
- 2. Malicious User: r.stern
- 3. 2,850 files · 430.0 MB staged
- 4. 180.0 MB exfiltrated
- 5. 2,510 deleted; 340 / 53,820,040 bytes remain
- 6. Systems: VEND-APP, POSMGT, STAGE-01

POTENTIAL

- 1. Cardholder data may be exfiltrated, contents unverified
- 2. Scheduled task triggers memory dump tools to spread foothold
- 3. malicious code is still active on the POS
- 4. No file-level auditing on SRV-CARDPROC
- 5. Credential of a.mizrahi and r.stern have been stolen

What we could not determine and why

UNRESOLVED QUESTION	WHY UNKNOWN	DATA TO CLOSE
Actions performed by configuration file on POS terminals	No data source	Deploying EDR on POS endpoints, forensic investigation on ngpos-cfg.exe
The attacker's foothold in the internal network	Insufficient time	Forensic disk analysis of SRV-VEND-APP and domain controller
Which vendor account used for the initial access	No data source	Forensics of IP address
Exact execution details of scheduled task NGSupplierSync	No data source	Task Cache Registry & Process Tree Analysis
What type of data send to edge-sync-eu.net	No access	PCAP files, Web application access logs, WAF telemetry
Initial credential theft method for r.stern and a.mizrahi	No access	Memory forensic dumps from compromised hosts.
Identity behind POST requests to edge-sync-eu.net	No data source	Endpoint EDR telemetry

MITRE ATT&CK and detection gaps

STAGE	Mitre ATT&CK	Detected by what?
Portal login + enumeration	Valid Accounts and Reconnaissance	Weblogs
w3wp.exe cmd.exe	Discovery & Execution	Windows event
Scheduled task create	Persistence	Windows event
a.mizrahi , r.stern lateral logons	Privilege Escalation and Credential Access	Windows event
ngpos-cfg.exe to 34 POS	Execution and Defense evasion	Windows event
Automated POS collection and Archive	Collection and Defense evasion	Fileaudit
6 outbound POSTs 180 MB	Exfiltration over Web Service	Proxy volume only
Scheduled task and Mass file deletion	Defense Evasion	Windows event and Fileaudit

How we used AI – and what it got wrong

USED FOR

1. Syntax of complex queries for multi stage aggregation to build more accurate results
2. Standard POS/CARDPROC transaction flow - described to us in general terms, no data shared.
3. Generate the slides of this presentation
4. Helped us to calculate time difference between events to find non-human behaviour

FAILED ON

1. hallucinated on timeline, logs, and involved personalities
2. invented fields for none existent logs
3. Failed to convert UTC and UTC+ 3 timezones
4. propose a correlation between unrelated events

Recommendations

TIER 1

- Threat intelligence Enrichment on IP and Domain
- Protect 340 surviving files
- Preserve proxy, VPN, web, Windows and file-audit logs
- Read in EDR: process tree, device timeline, file details
- Write a shift handover and transfer an open case
- Recommend rule creation and tuning
- Escalate severity, based on asset or identity context

REQUIRES APPROVAL

- Deploy EDR to all 42 POS terminals
- Isolate R.stern and a.mizrahi and revoke SMB sessions
- Review supplier-portal controls
- Block edge-sync-eu.net and 77.124.66.19 on firewall and proxy
- Monitor access requests from the web
- Call a high-ranking official late at night.

MANAGEMENT / LEGAL

- Forensically assess cardholder-data exposure
- Notify the needed parties for the breach and face legal actions (within 24 hours, no later than 72)
- Fund backup and recovery coverage for CARDPROC, DC-01, POSMGT, STAGE-01 and branch estate
- Shut down the POS's until the breach is fixed and no longer possible
- Deploy a red team to try and recreate the attack to make sure this kind of thing never happens
- Alert on web-worker shells, tasks, mass writes/deletes and POST volume

Questions?

Team B

